Proč tato pravidla

Motivace za rámcem pro AI-asistovaný vývoj

Doprovodný text k dokumentu „Pravidla pro AI-asistovaný vývoj“

Krátké zamyšlení nad tím, z čeho rámec vyrostl - principy, ne návod.

1. Rychlost není totéž co zvládnutí

AI nástroje pro asistenci při vývoji dramaticky zvyšují rychlost, s jakou vzniká kód. To je jejich hlavní přínos - a zároveň jejich hlavní riziko. Rychlost bez porozumění nevede k lepšímu softwaru; vede k softwaru, který nikdo nedokáže bezpečně udržovat ani obhájit.

Jádro problému je nenápadné: AI generuje kód, který je syntakticky správný a projde základními testy - ale sám o sobě neodráží architektonická rozhodnutí, model hrozeb ani provozní souvislosti, pokud je někdo vědomě nezadal a neověřil. „Funguje to“ a „rozumíme tomu“ nejsou totéž. Mezera mezi nimi se přitom při použití AI nezvětšuje pomalu - otevírá se rychlostí, jakou kód přibývá.

2. Co se ztrácí, když zmizí mentální model

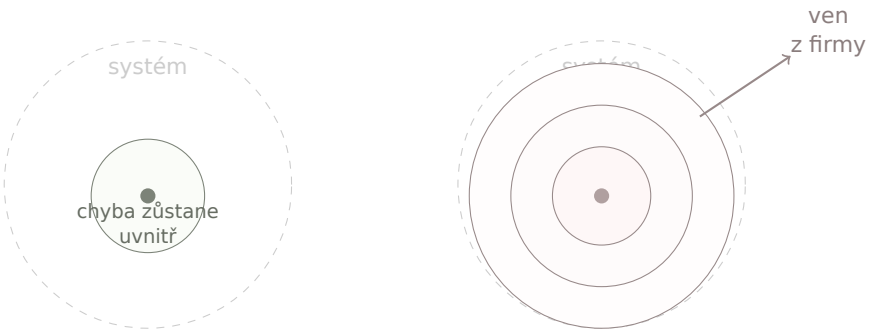
Vstupní bariéra klesla natolik, že lze sestavit funkční aplikaci, aniž by kdokoli prošel fází hlubokého pochopení. Kód existuje, běží - ale mentální model, který by někdo unesl v hlavě, nevznikl.

Důsledky se neprojeví hned. Přijdou později: každá netriviální změna se stává hazardem, protože není jasné, co co ovlivňuje. Ladění se mění z analýzy na metodu pokus-omyl. A když původní autor odejde, kód nemá kdo převzít - ne proto, že by byl složitý, ale proto, že nikdy neexistovalo porozumění, které by se dalo předat.

Tohle není problém AI. Je to starý problém, který AI jen zrychluje a zlevňuje natolik, že se objevuje častěji a dřív.

3. Ne každá chyba je stejná

Intuice, že „chyba je chyba“, je v provozu k ničemu. Chyba ve formátování data je lokální - projeví se, najde se, opraví. Chyba v tom, jak se zachází s daty nebo přístupy, se nemusí projevit vůbec - dokud se neprojeví jako incident, měsíce po nasazení.



Dvě chyby mohou být stejně „velké“ v kódu a přitom mít úplně jiný dosah: jedna zůstane v místě vzniku, druhá se šíří vrstvami systému - a v nejhorším případě až ven, k uživatelům nebo do dat, kde už nejde o bug, ale o incident. Velikost dopadu je ale jen první ze tří otázek.

Proto má smysl ptát se ne „kdo nebo co kód napsal“, ale: jak velkou škodu chyba způsobí, jak rychle ji poznáme a jak snadno ji vrátíme.

- **Ověřitelnost - jak rychle to poznáme.** Některá chyba spadne v testu hned, jiná tiše čeká. Špatná ověřitelnost je zákeřná právě tím, že velký dosah a pozdní odhalení se násobí: než se chyba projeví, je už všude.
- **Reverzibilita - jak snadno to vrátíme.** Vratná migrace nebo přepínač funkce sníží riziko i u velkého dosahu - omyl prostě vezmeme zpět. Nevratná operace (smazaná data bez zálohy) je nebezpečná i při malém dosahu, protože druhý pokus už není.

Tyto tři otázky - dosah škody, ověřitelnost, reverzibilita - platily dávno před AI. AI je nemění. Jen zvyšuje sázku tím, že umožňuje vyrobit rizikový kód rychleji než kdy dřív.

4. Když je v sázce víc než kód

Některé oblasti nesou víc než jen riziko chyby. Tam, kde se pracuje s osobními údaji nebo s know-how, má nedbalost i právní a obchodní rozměr - regulace jako NIS2 nebo GDPR nejsou jen administrativa, ale popis toho, co se stane, když dosah škody překročí hranici firmy. A nástroj, který odesílá kód či data ke zpracování třetí straně, je vždy odchozím kanálem, ne jen pomocníkem.

Detaily těchto témat patří do samotných pravidel, ne sem. Zde stačí říct, proč na nich záleží: protože tady přestává jít o eleganci kódu a začíná jít o odpovědnost.

5. K čemu rámec míří

Cílem není AI zakázat ani omezit. Není to ani oslava nástroje. Je to snaha držet jednoduchou rovnováhu: rychlost generování vyvážená odpovídající mírou porozumění, ověření a kontroly - nejvíc tam, kde selhání bolí nejvíc.

Zkušený člověk s AI udělá víc práce za méně času, ale stále rozumí každému řádku, který pustí do produkce. To je laťka, ke které pravidla míří. Vše ostatní jsou jen způsoby, jak ji udržet.

6. Rozcestník: co už existuje a na co to míří

Tento rámec nevznikl v prázdnu a nesnaží se nahradit práci, kterou jinde odvedli lépe. Přehled je záměrně tady, v motivačním textu, a ne v pravidlech: pravidla se nemají měnit pokaždé, když vyjde nový dokument. Odpovídá stavu v době psaní a zastará - pravidla ne.

Kde je dokument popsán podle vlastní charakteristiky projektu, a ne z přímého čtení, je to u položky uvedeno.

- **OWASP GenAI Security Project** - rodina dokumentů, ne jeden text. Míří v ní každý dokument jinam, a proto stojí za to je rozlišit:
  - **Top 10 for LLM Applications** - nejstarší a nejcitovanější text rodiny: deset nejzávažnějších rizik jazykových modelů v aplikacích. Ostatní dokumenty se na něj odvolávají jako na základ.
  - **Agentic AI - Threats and Mitigations** - podrobná taxonomie hrozeb agentických systémů (T1–T17). Referenční slovník projektu, klasifikace spíš než návod.
  - **Top 10 for Agentic Applications** (2025) - deset rizik agentických aplikací (ASI01–ASI10) ve známém formátu. Má sloužit jako kompas; autoři v úvodu sami přiznávají, že šíře publikací projektu se špatně převádí do praxe. Nejblíž tomuto rámci jsou položky o neočekávaném spuštění kódu a o zneužití důvěry mezi člověkem a agentem - obě ale míří na provoz agenta, ne na okamžik slučování změny.
  - **Securing Agentic Applications** a **Agentic Threat Modelling Guide** - návody pro architekturu, návrh, vývoj, nasazení a threat modeling. Vstupují na začátku, při návrhu systému.
  - **State of Agentic AI Security and Governance** - přehled stavu řízení agentické AI: co organizace zavádějí a kde jsou mezery. Právě zde je pojmenovaná potřeba kalibrovat míru dohledu podle následku, aniž by k ní byl dán postup.
  - **AIVSS** - skórovací systém pro agentická zranitelnosti. Slouží k prioritizaci už nalezených problémů, ne k rozhodnutí, kde pracovat opatrně předem.
- **TrustX ARC** (Responsible AI Institute, 2026). Bodovací rubrika, která agentickému systému přiřadí rizikový stupeň podle dvanácti dimenzí a k němu sadu organizačních kontrol; má i samostatné rozšíření pro kódovací asistenty. Jednotkou posouzení je *nástroj*; vstupuje při jeho pořizování a při periodickém přehodnocení. Předpokládá roli, která posouzení provede - u nejvyššího stupně až souhlas vedení.

- **Security-Focused Guide for AI Code Assistant Instructions** (OpenSSF Best Practices Working Group). Návod, jak psát instrukce pro kódovací asistenty, s rozsáhlou sadou vzorových direktiv od validace vstupů po podepisování obrazů. Míří přímo na vývojáře a je z celého seznamu nejblíž tomu, co dělá tento rámec. Sami upozorňují, že se z direktiv má vybírat, ne je kopírovat celé - kritérium výběru ale nedávají.
- **AI Codebase Maturity Model** (2026). Popisuje pět (v novější verzi šest) úrovní zralosti *zpětnovazební infrastruktury* kolem AI - od žádné přes instrukční soubory a měření až po uzavřené smyčky. Jednotkou je repozitář jako celek a úrovně se nepřeskakují. Užitečné pro rozhodnutí, jak rychle může tým jet celkově; neříká, kde uvnitř repozitáře to platí jinak.
- **Governed AI-Assisted Engineering (GAIE)** (Kang, arXiv:2606.22484, 2026). Tři stupně dohledu pro agentické generování kódu v regulovaných odvětvích - od člověka ve smyčce přes člověka nad smyčkou po automatiku s monitoringem. Jednotkou je *úloha*; o zařazení rozhoduje regulační dopad, blízkost zákazníkovi, vratnost a citlivost dat, a každý stupeň předepisuje doklady pro audit. Ukotvení je záměrně regulační: rámec se mapuje na politiku thajské centrální banky a dále na MAS, NIST AI RMF, ISO/IEC 42001 a AI Act. Předpokládá tedy regulátora a kontrolní funkci, které to bude dokládat - tam, kde nejsou, zbývá z rámce klasifikace bez adresáta.

Mimo rozsah tohoto přehledu zůstávají obecné rámce řízení rizik AI (NIST AI RMF, ISO/IEC 42001, AI Act). Nebyly zde posuzovány a jejich vynechání není hodnocením - míří na jinou vrstvu a jiného čtenáře.

Společné těmto dokumentům je, že vstupují jinde než u merge requestu: při pořizování nástroje, při návrhu architektury, při auditu, při psaní kódu. Žádný z nich neodpovídá vývojáři na otázku, kterou má před sebou v okamžiku slučování: *co přesně mám u téhle změny ověřit a proti čemu*. Právě tam stojí tento rámec - a proto z něj lze číst dvojím způsobem:

- **Jako jediný dokument.** V malé firmě nebo v oddělení, které je uvnitř velké firmy fakticky malou firmou, žádná z výše uvedených rolí neexistuje a nikdo ji neobsadí. Pak je tento rámec vším, co bude zavedeno - a je tak psaný: bez nové role, bez nového nástroje, rozhodnutelný tím, kdo tu práci dělá.
- **Jako chybějící patro.** Tam, kde už nějaká governance je, tento rámec nic z ní nenahrazuje. Doplňuje jediné místo, kam žádný z těch dokumentů nedosáhne, protože tam ani nemíří - rozhodnutí u konkrétní změny, u konkrétní cesty v repozitáři.

Čím tento rámec být nemá, je překladová tabulka mezi ostatními. Tvrdit, že určité pravidlo „odpovídá“ konkrétnímu ustanovení cizího dokumentu, je závazek, který zastará s jeho příští verzí a který tady nikdo neponese. Přehled výše říká, kam který projekt míří - ne že si jsou navzájem rovny.